

Report Creazione di Gruppi in Windows Server 2022

S10L5 | Tema scelto The Big Bang Theory |

Indice

1. Obiettivo

2. Progettazione dei Gruppi e degli Utenti

Step 1 Creazione delle Unità Organizzative e dei gruppi

Step 2 Assegnazione utenti ai gruppi di reparto

3. Presidenza come Autorità Massima

4. Creazione delle Cartelle e delle Condivisioni

5. Configurazione dei Permessi NTFS

Step 3 Disabilitazione eredità e permessi espliciti

6. Test di Accesso da Client Windows 11

Test negativo Accesso a una cartella di un altro reparto

7. Problema Ricontrato e Soluzione

8. Conclusioni

Macchina	Ruolo	Dominio	OS / Servizi
CALTECH-DC	Domain Controller	Caltech.local	Windows Server 2022 - AD DS, DNS
Win11-Client	Client di test	Caltech.local	Windows 11 - domain-joined

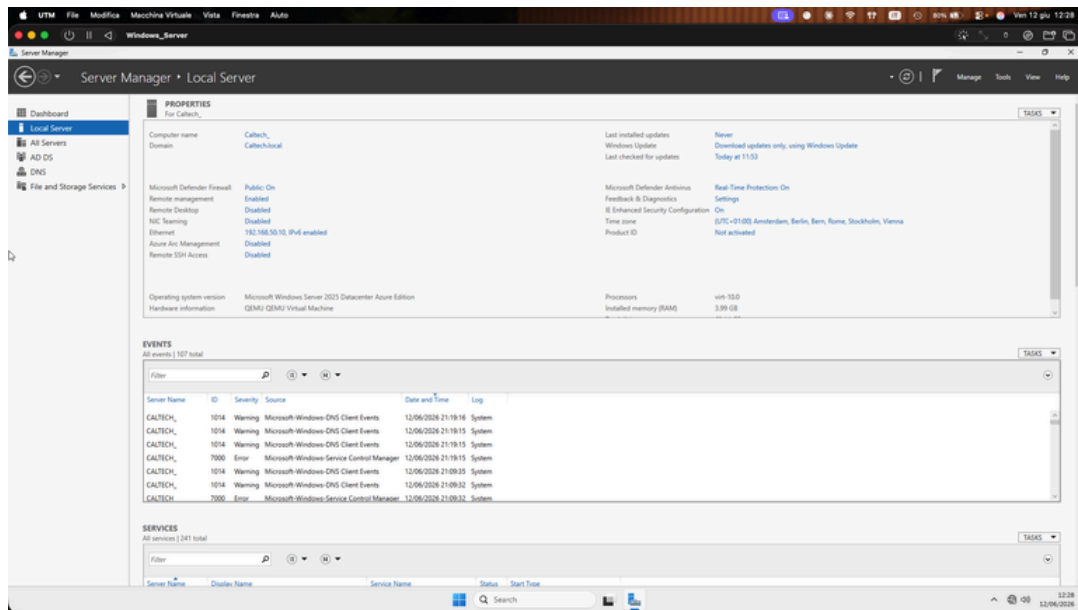
1. Obiettivo

L'esercitazione S10L5 ha come obiettivo la progettazione e la configurazione di una struttura di **gruppi di sicurezza in Active Directory** su Windows Server 2022, con relativa creazione di cartelle condivise e applicazione di permessi NTFS coerenti con il principio del **minimo privilegio** (RBAC). Per rendere lo scenario più concreto e memorizzabile, i reparti aziendali sono stati modellati sui personaggi della serie The Big Bang Theory: ogni gruppo corrisponde a una professione, con una cartella condivisa dedicata e permessi differenziati in base al ruolo.

2. Progettazione dei Gruppi e degli Utenti

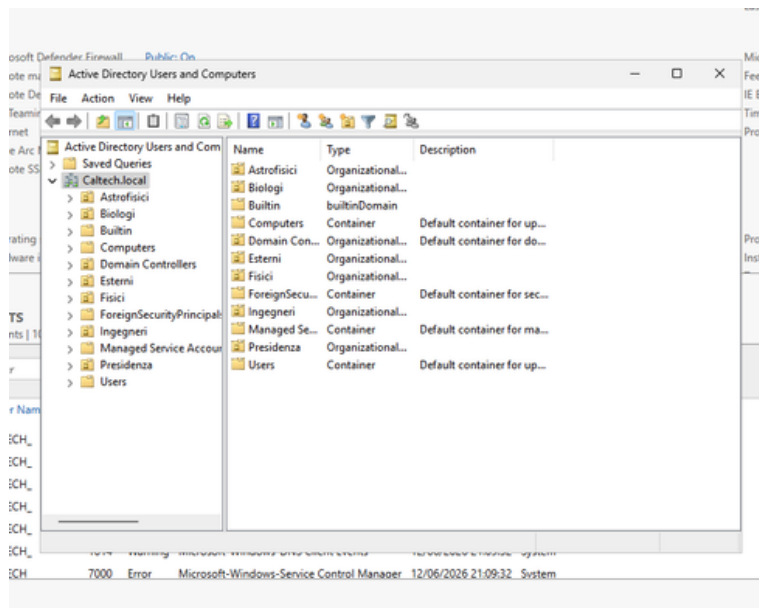
Sono stati creati sei gruppi di sicurezza globali (uno per ogni Unità Organizzativa omonima), ciascuno associato a una cartella condivisa C:\Caltech\<Reparto> e a permessi NTFS specifici. La tabella seguente riassume i gruppi, gli utenti membri, la cartella associata e il permesso NTFS assegnato:

Gruppo	Utenti	Cartella	Permesso NTFS
Fisici	Sheldon Cooper, Leonard Hofstadter	C:\Caltech\Fisici	Modify
Astrofisici	Raj Koothrappali	C:\Caltech\Astrofisici	Modify
Ingegneri	Howard Wolowitz	C:\Caltech\Ingegneri	Modify
Biologi	Amy Farrah Fowler	C:\Caltech\Biologi	Modify
Esterni	Bernadette Rostenkowski, Penny Hofstadter	C:\Caltech\Esterni	Read
Presidenza	President Siebert	C:\Caltech\Presidenza	Full control (+ su tutte)



Step 1 Creazione delle Unità Organizzative e dei gruppi

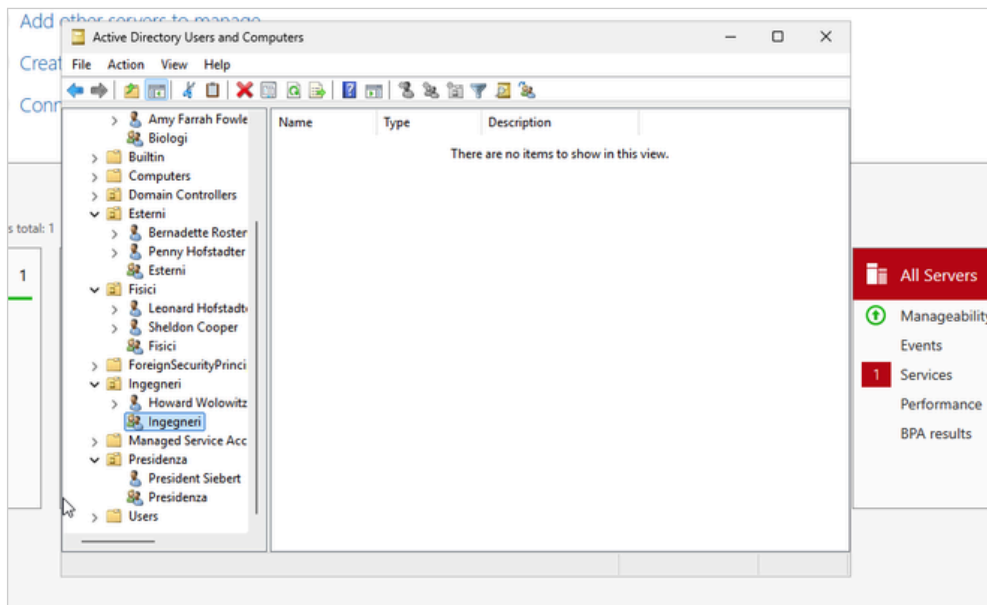
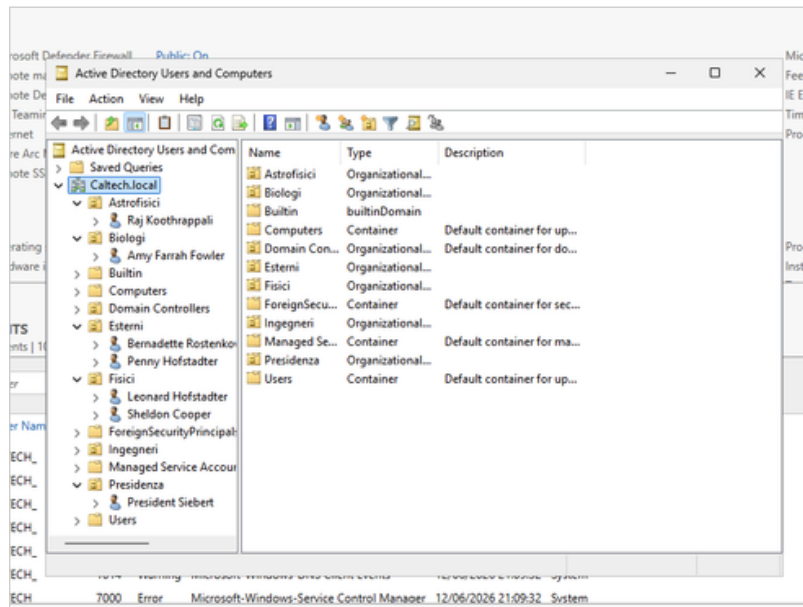
In **Active Directory Users and Computers** sono state create sei OU (una per reparto: Astrofisici, Biologi, Esterni, Fisici, Ingegneri, Presidenza), ciascuna contenente il gruppo di sicurezza omonimo e gli utenti del reparto.



Step 2 Assegnazione utenti ai gruppi di reparto

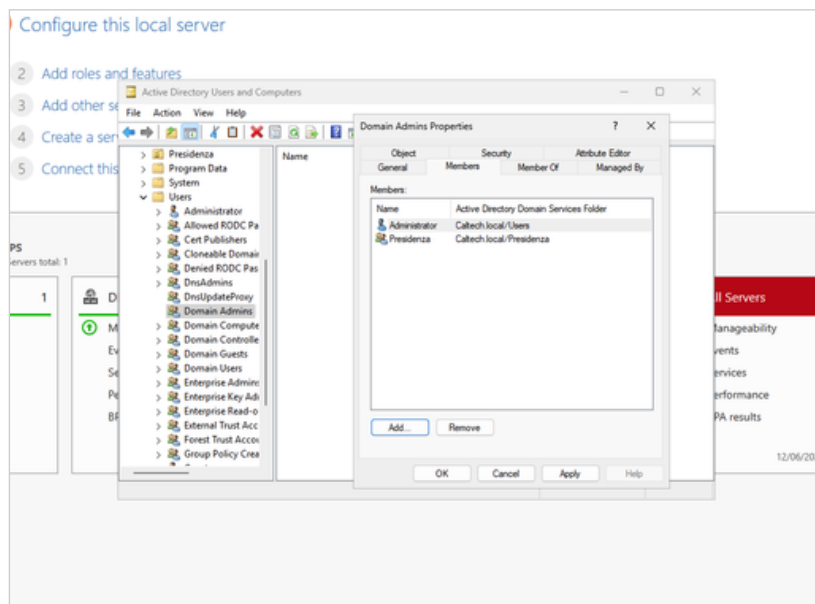
Gli utenti sono stati creati e inseriti nel gruppo del proprio reparto, restando fedeli alla serie:

- Raj (astrofisico) in Astrofisici,
- Amy (biologa) in Biologi,
- Leonard e Sheldon (fisici) in Fisici,
- Bernadette (lavora alla Zangen, non a Caltech) e Penny (attrice, già Hofstadter) in Esterni come utenti esterni con accesso in sola lettura.



3. Presidenza come Autorità Massima

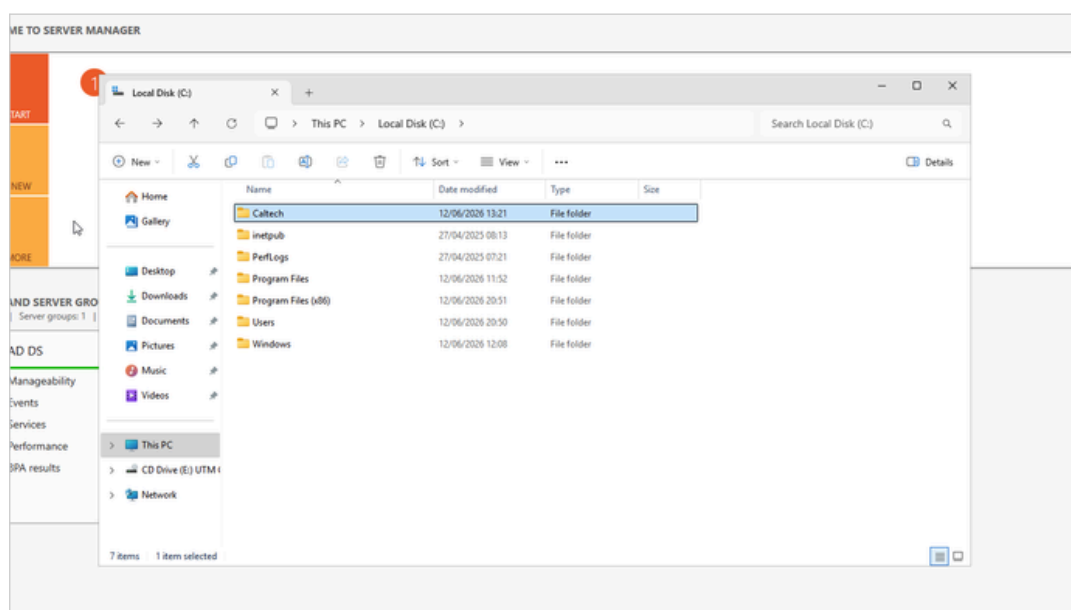
Per rappresentare l'autorità massima dell'organizzazione (il rettore dell'università), il gruppo **Presidenza** è stato aggiunto al gruppo predefinito **Domain Admins**. Questo garantisce a President Siebert pieni poteri amministrativi su tutto il dominio, oltre al permesso esplicito di **Full control** impostato su ciascuna cartella di reparto, per coerenza e leggibilità della configurazione anche in caso di future modifiche ai privilegi di Domain Admins.

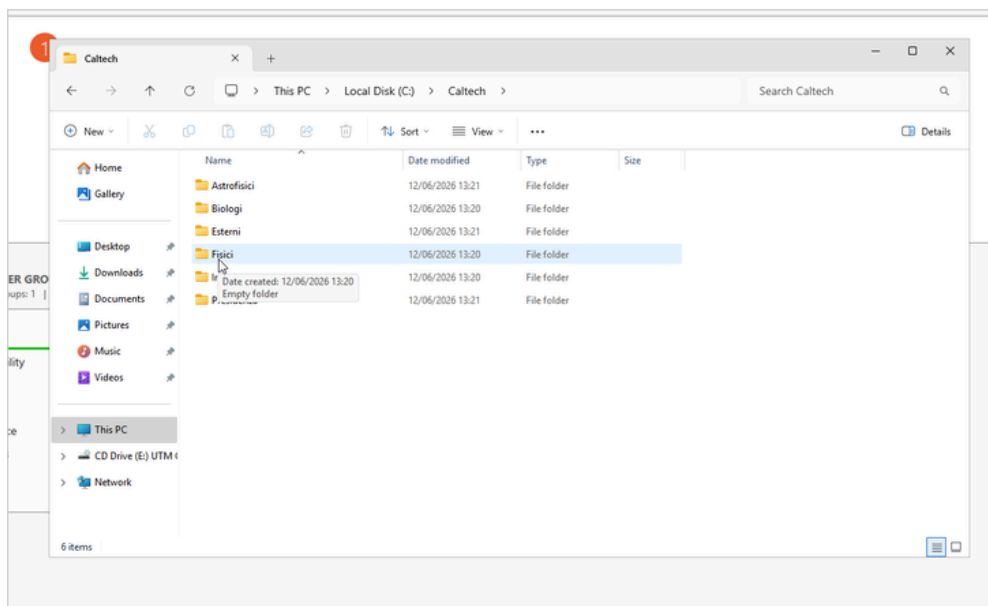


Nota: Su ogni cartella di reparto, oltre ai gruppi Administrators e SYSTEM (sempre presenti per gestione di sistema), restano solo il gruppo del reparto e il gruppo Presidenza. Non sono state usate regole di Deny esplicite: disabilitando l'eredità e lasciando solo le entry necessarie, chiunque non sia elencato è automaticamente escluso (deny implicito).

4. Creazione delle Cartelle e delle Condivisioni

È stata creata la cartella radice C:\Caltech e, al suo interno, una sottocartella per ciascun reparto. Ogni sottocartella è stata condivisa in rete con un nome di share corrispondente al reparto (es. \\Caltech_\Fisici), con permessi di condivisione (Share Permissions) limitati al gruppo di reparto e a Presidenza.

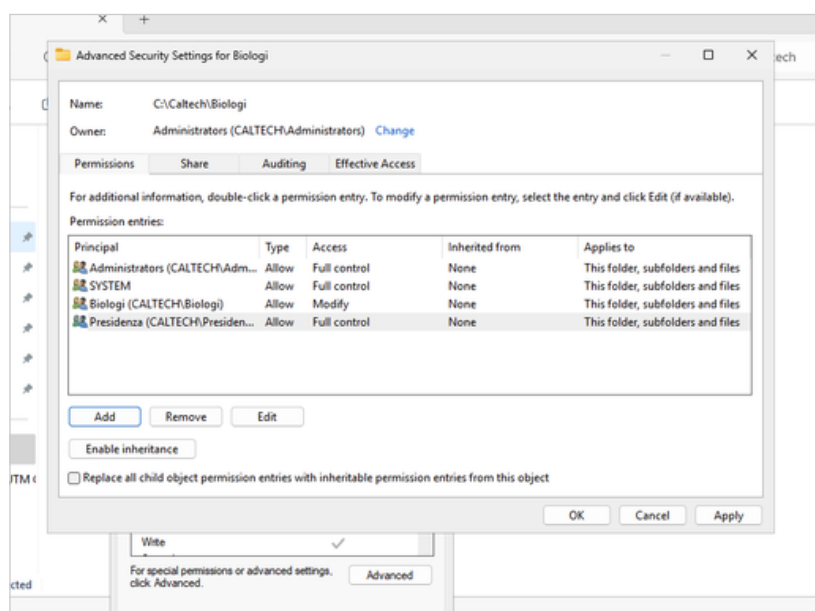




5. Configurazione dei Permessi NTFS

Step 3 Disabilitazione eredità e permessi espliciti

Su ogni sottocartella di reparto è stata **disabilitata l'eredità** dei permessi dalla cartella padre C:\Caltech (che mantiene gli ACL di default di Windows, inclusi BUILTIN\Users e Authenticated Users), e sono state lasciate solo quattro voci esplicite: **Administrators** (Full control), **SYSTEM** (Full control), il **gruppo di reparto** (Modify, o Read per Esterni) e **Presidenza** (Full control). In questo modo nessun altro utente di dominio eredita accesso alla cartella.



La verifica è stata effettuata anche con il comando `icacls`, che conferma l'assenza del flag (I) (inherited) sulle quattro voci di Biologi, a differenza della cartella padre C:\Caltech dove le voci ereditate da C:\ sono ancora presenti ma non si propagano ai sottolivelli protetti:

```

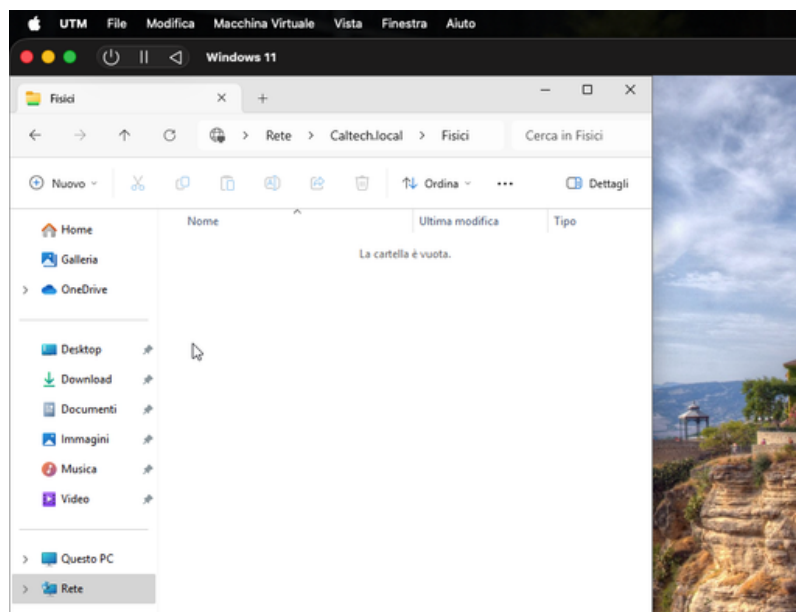
icacls "C:\Caltech\Biologi"
C:\Caltech\Biologi BUILTIN\Administrators:(OI)(CI)(F)
NT AUTHORITY\SYSTEM:(OI)(CI)(F)
CALTECH\Biologi:(OI)(CI)(M)
CALTECH\Presidenza:(OI)(CI)(F)

icacls "C:\Caltech"
C:\Caltech BUILTIN\Administrators:(I)(OI)(CI)(F)
NT AUTHORITY\SYSTEM:(I)(OI)(CI)(F)
BUILTIN\Users:(I)(OI)(CI)(RX)
NT AUTHORITY\Authenticated Users:(I)(M)
NT AUTHORITY\Authenticated Users:(I)(OI)(CI)(IO)(M)

```

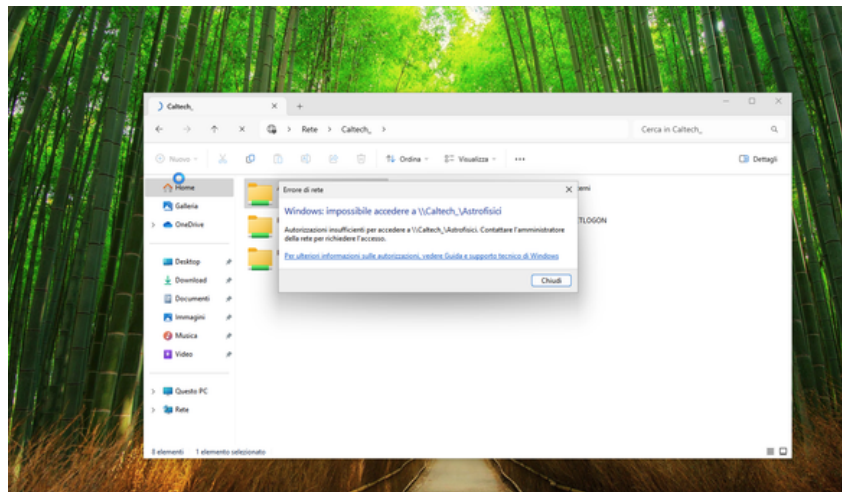
6. Test di Accesso da Client Windows 11

Per validare la configurazione sono stati eseguiti test reali da un client Windows 11 domain-joined, effettuando il login come utenti **non amministratori** (CALTECH\sheldon e CALTECH\leonard, entrambi membri del solo gruppo **Fisici**) e provando ad accedere alle varie cartelle condivise.



Test negativo Accesso a una cartella di un altro reparto

Leonard, anche lui membro del solo gruppo **Fisici**, tenta di accedere alla condivisione `\\Caltech_\Astrofisici` (reparto di Raj, non suo). Windows restituisce l'errore "Autorizzazioni insufficienti per accedere a `\\Caltech_\Astrofisici`. Contattare l'amministratore della rete per richiedere l'accesso.", confermando che NTFS e permessi di condivisione bloccano correttamente l'accesso agli utenti non autorizzati.



7. Problema Ricontrato e Soluzione

Durante i primi test, sia Sheldon che Leonard (entrambi membri del solo gruppo Fisici) riuscivano ad **accedere a tutte le cartelle condivise**, incluse quelle di reparti diversi dal proprio (es. Biologi, Astrofisici), nonostante i permessi NTFS sulle singole cartelle risultassero corretti (verificati sia da GUI con "Effective Access" sia da riga di comando con `icacls`): il calcolo dei permessi effettivi per Sheldon su Biologi restituiva correttamente "accesso negato" su tutte le voci, eppure l'accesso reale veniva concesso.

Sono state escluse, una per una, le cause più comuni: appartenenza errata a gruppi (verificata in ADUC, gli utenti erano solo in Domain Users + Fisici), credenziali salvate in Credential Manager (assenti), percorso fisico delle condivisioni errato (verificato con `Get-SmbShare`, ogni share puntava correttamente a `C:\Caltech\<Reparto>`), membri errati del gruppo AD del reparto (verificato, contenevano solo l'utente corretto).

La causa reale era nei **permessi di condivisione SMB (Share Permissions)**: ogni share aveva ancora, come refuso della creazione iniziale, il gruppo predefinito Everyone con permesso di lettura/modifica. Poiché i permessi effettivi risultano dalla combinazione (intersezione) di permessi NTFS e permessi di condivisione, ma Everyone a livello di condivisione consentiva comunque la connessione e l'enumerazione della cartella a qualsiasi utente autenticato, mascherando le restrizioni NTFS nei test eseguiti tramite il percorso del dominio.

Soluzione: Rimosso il gruppo Everyone dai permessi di condivisione di tutte le share di reparto, lasciando solo il gruppo del reparto e Presidenza (stesso criterio già applicato a livello NTFS). Dopo la modifica, i test ripetuti da Sheldon e Leonard hanno dato i risultati corretti: accesso consentito solo alla propria cartella di reparto, "Autorizzazioni insufficienti" su tutte le altre.

Nota tecnica: Durante il troubleshooting, il comando `dir \\Caltech.local\<share>` restituiva sempre "Impossibile trovare il file specificato", anche per share permesse. La causa era la risoluzione del nome a dominio (FQDN) non disponibile per connessioni UNC dirette da riga di comando: usando l'hostname NetBIOS del Domain Controller (`\\Caltech_\<share>`) il test ha funzionato correttamente. Da Esplora File, invece, la navigazione tramite "Rete > Caltech.local" funziona perché usa il meccanismo di browsing di rete del dominio, diverso dalla risoluzione DNS diretta.

8. Conclusioni

L'esercitazione ha permesso di applicare in modo pratico i concetti di **RBAC e minimo privilegio** in un ambiente Active Directory: gruppi di sicurezza dedicati per reparto, cartelle condivise isolate tramite permessi NTFS espliciti (eredità disabilitata) e permessi di condivisione coerenti, un gruppo Presidenza con autorità massima (Domain Admins + Full control esplicito ovunque). Il problema riscontrato durante i test, l'accesso indesiderato dovuto al refuso Everyone nei permessi di condivisione, ha evidenziato un punto spesso sottovalutato: i permessi NTFS da soli non bastano a proteggere una risorsa condivisa in rete, perché il permesso effettivo è sempre il più restrittivo tra NTFS e Share Permissions, ma una share permission troppo permissiva può comunque consentire l'accesso iniziale e mascherare un audit superficiale dei soli permessi NTFS.